

Capstone Project

Planning to Secure and Monitor a
Mid-sized Enterprise Network

Masterschool (MSIT)
by Ruben Faude

Directory

[Threat Modeling](#)

[Framework Comparison](#)

[Firewall & ACL Design](#)

[Device Hardening Plan](#)

[Logging & Monitoring Plan](#)

[SOC Workflow](#)

[Incident Response Process](#)

[Implementation Roadmap](#)

Threat Modeling

Perimeter Breach (Edge-VM): As the primary proxy and entry point, the Edge-VM is the most exposed target for external exploitation.

Lateral Movement (Identity → Management): Attempted unauthorized access from the Identity Zone (VLAN 30) to the high-security Management Zone (VLAN 20).

Administrative Credential Theft: Compromising the static credentials used to manage OPNsense or the MGMT-VM, granting full network control.

Internal DNS Spoofing: Attacking the centralized Unbound DNS resolver on the OPNsense gateway to redirect internal traffic to malicious endpoints.

Exfiltration via Identity Zone: Misusing the Identity Zone's internet access to exfiltrate sensitive data (e.g., domain hashes) to external Command & Control (C2) servers.

Management Tunnel Exploitation: Unauthorized access to the OPNsense web GUI by exploiting the Floating Rule/SSH tunnel established between the host Mac and the Edge-VM.

Risk is calculated using the formula $\text{Risk} = \text{Likelihood} \times \text{Impact}$, with scores ranging from 1 to 5.

Threat Scenario	Likelihood (L)	Impact (I)	Risk Score	Risk Level
1. Perimeter Breach (Edge)	4	3	12	Medium
2. Lateral Movement (ID → MGMT)	2	4	8	Medium
3. Credential Theft (Admin)	2	5	10	High
4. DNS Spoofing	3	3	9	Medium
5. Data Exfiltration (ID)	3	4	12	High
6. Tunnel Exploitation (Floating)	2	5	10	High

This visualization categorizes the identified threats to prioritize security control implementation.

Impact \ Likelihood	1 (Rare)	2 (Unlikely)	3 (Possible)	4 (Likely)	5 (Certain)
5 (Catastrophic)		T3, T6			
4 (Major)		T2	T5		
3 (Moderate)			T4	T1	
2 (Minor)					
1 (Negligible)					

Legend: T1 = Perimeter, T2 = Lateral Movement, T3 = Credential Theft, T4 = DNS Spoofing, T5 = Exfiltration, T6 = Tunnel Exploitation.

The following controls from the established security stack serve as primary mitigations for the identified risks:

Threat Scenario	Security Controls & Mitigation Measures
Perimeter Breach	Strict WAN ingress filtering and isolated DMZ segment for the Edge-VM.
Lateral Movement	Zero-trust VLAN isolation; OPNsense "Deny" rules block all traffic initiated from Zone 30 toward Zone 20.
Credential Theft	Static IP tracking for anomaly detection and planned implementation of MFA for management endpoints.
DNS Spoofing	Enforcement of centralized DNS resolution via OPNsense with hardened Unbound configuration.
Data Exfiltration	Strict egress filtering on the Identity interface, allowing only necessary protocols to the internet.
Tunnel Exploitation	Use of encrypted SSH tunneling from the host Mac; Floating Rules limit GUI access to the specific tunnel endpoint.

Framework Comparison

To establish a robust security posture for a mid-sized enterprise, three industry-standard frameworks were evaluated:

- **ISO/IEC 27001:** Focused on a formal Information Security Management System (ISMS). While excellent for compliance and certification, its heavy focus on documentation and legal requirements makes it less actionable for the initial technical design phase of a SOC lab.
- **MITRE ATT&CK:** An essential knowledge base for adversary tactics and techniques (TTPs). While it is invaluable for the later "Detection" and "Response" phases (Segment 4), it lacks the high-level governance structure needed for initial network architecture.
- **NIST CSF 2.0:** Selected as the primary framework to bridge the gap between technical controls and business strategy.

Rationale & Justification

I chose the NIST CSF (National Institute of Standards and Technology - Cybersecurity Framework v2.0) as a guiding framework because my task is to design a medium-sized enterprise network. The NIST CSF is defender-centric, meaning that the construction of a resilient and defensible network is central to this framework. Although MITRE ATT&CK is a good complement to NIST CSF for a holistic perspective on cybersecurity and secure network design, the NIST CSF is more focused on defensive capabilities rather than offensive TTPs. That is why I chose this framework: it provides more orientation guidelines for constructing a network. The core of this framework is the standardized split into the following actionable steps, applicable to most, if not all, network designs:

- **Govern:** Establish the organization's cybersecurity strategy and oversight;
- **Identify:** Understand your assets, risks, and data;
- **Protect:** Implement safeguards to ensure delivery of services;
- **Detect:** Develop activities to identify the occurrence of a cybersecurity event;
- **Respond:** Take action once a detected event occurs;
- **Recover:** Restore capabilities or services that were impaired.

By following these steps in network design, a strong security foundation is built. With the focus on the current profile and the prospective target profile, network engineers can easily identify

the gaps between the current state and the desired security posture. Providing four tiers of cybersecurity adaptation and workflow implementation, companies can find out how well they are equipped to deal with security-related risks. By prioritizing supply chain risks and established B2B trust relationships, another layer of holistic network design is accomplished. Focusing on target outcomes, the NIST CSF is vendor-agnostic, meaning as long as a certain outcome is provided, it does not care about the manufacturer of hardware/software assets. All these different aspects allow for flexible security implementation, dynamic assessment and prospective optimization. In summary, the NIST CSF not only provides selective security mechanisms but also offers a holistic approach to constructing and securing a network with a significant focus on sustainability and prospective adaptations.

Firewall & ACL Design

Management Zone (VLAN 20 / LAN)

Rule #	Source	Destination	Port/Protocol	Action	Rationale
1	MGMT Net	Any	ICMP (Ping)	Pass	Network troubleshooting
2	MGMT Net	LAN Address	UDP/53 (DNS)	Pass	DNS resolution via OPNsense
3	MGMT Net	IDENTITY_NET	Any	Pass	Full Admin access to ID zone
4	MGMT Net	SECURITY_LOG	Any	Pass	Full Admin access to ID zone
5	MGMT Net	WAN Net	Any	Pass	Internet access for updates

Management Zone (configured as 'LAN' interface in OPNsense)

Identity Zone (VLAN 30 / IDENTITY_NET)

Rule #	Source	Destination	Port/Protocol	Action	Rationale
1	ID Net	MGMT Net	Any	Block	Zero Trust: Isolation of Admin zone
2	ID Net	SECURITY_LOG	Any	Block	Prevention of lateral movement to SOC
3	ID Net	WAN Net	Any	Pass	Internet access for

					Samba/OS updates
--	--	--	--	--	------------------

Security Zone (VLAN 40 / SECURITY_LOG)

Rule #	Source	Destination	Port/Protocol	Action	Rationale
1	SEC Net	MGMT Net	Any	Block	Isolation of Management segment
2	SEC Net	WAN Net	Any	Pass	Internet access for SIEM updates

Planned Rules for SIEM (Wazuh / Monitoring)

Source	Destination	Port/Protocol	Action	Rationale
Any Internal	SEC-VM	UDP/1514	Pass	Wazuh Agent event data collection
Any Internal	SEC-VM	TCP/1515	Pass	Wazuh Agent enrollment & management
MGMT-VM	SEC-VM	TCP/443	Pass	Secure access to Wazuh Dashboard (WUI)

Planned Rules for Identity (Samba AD / Authentication)

Source	Destination	Port/Protocol	Action	Rationale
Any Internal	ID-VM	TCP/UDP 389, 636	Pass	LDAP/LDAPS for identity queries
Any Internal	ID-VM	TCP/UDP 88, 464	Pass	Kerberos authentication services
Any Internal	ID-VM	TCP/UDP 135, 445	Pass	RPC & SMB for domain services

Hardening Adjustments (Egress Filtering)

Source	Destination	Port/Protocol	Action	Rationale
All Internal	WAN	TCP 80, 443	Pass	Restrict Internet to HTTP/S only (Egress Filter)
All Internal	WAN	Any	Block	Final "Catch-all" block for

				unauthorized WAN traffic
--	--	--	--	--------------------------

Device Hardening Plan

1. Foundation: Supply Chain & Software Integrity

Before any configuration begins, the integrity of the base components must be guaranteed.

Hardening Measure	Implementation	Technical Detail / Rationale
Supply Chain Overview	Documentation of all image sources (github.com, Ubuntu/Canonical).	Ensures only trusted repositories are used for critical infrastructure.
Integrity Verification	Mandatory SHA-256 Checksum validation for all OS and Router images.	Prevents the use of tampered or corrupted installation media.
Minimal Footprint	Use of Ubuntu Server (no GUI) and OPNsense core.	Reduces the attack surface by eliminating unnecessary graphical components and libraries.

2. Software & Patch Management

Maintaining the latest security posture through proactive updates and pruning.

Hardening Measure	Implementation	Technical Detail / Rationale
Baseline Updates	Immediate execution of opnsense-update and apt update && apt upgrade.	Patches known vulnerabilities immediately after initial deployment.
Unnecessary Software	Removal of pre-installed tools (e.g., snapd, unnecessary cloud-init modules).	Minimizes background processes and potential exploitation vectors on Linux endpoints.
Vulnerability Scanning	Implementation of regular scans using tools like OpenVAS or Clair (planned for SEC-VM).	Proactively identifies missing patches or insecure configurations within the segments.

3. Network & Interface Hardening

Securing the entry points and limiting lateral movement.

Hardening Measure	Implementation	Technical Detail / Rationale
Closing Unused Ports	Implicit "Default Deny" policy on all OPNsense interfaces. Closing unused ports on Linux-VMs	Ensures only specifically requested traffic (e.g., DNS, ICMP, Management) is allowed.
Disable Unused	IPv6 Deactivation across all internal	Reduces protocol complexity and

Protocols	segments if not required.	prevents IPv6-specific tunneling or neighbor discovery attacks.
Service Binding	OPNsense GUI/SSH bound strictly to the MGMT (VLAN 20) interface.	Prevents access attempts from the Identity (30) or Security (40) zones.

4. Identity & Access Management (IAM)

Enforcing the human and technical barriers to the systems.

Hardening Measure	Implementation	Technical Detail / Rationale
Least Privilege	Alignment with NIST PR.AC-4.	Strictly isolates traffic between different security zones via dedicated virtual networks.
Permissions Setting	Use of sudo with specific command aliases; no direct root login permitted.	Ensures accountability and prevents accidental system-wide misconfigurations.
Secure Communications	Enforcement of SSH Key-based Authentication; passwords disabled.	Eliminates brute-force risks on administrative interfaces.

5. Management & Infrastructure Hardening

Protecting the "Keys to the Kingdom"—your management access.

Hardening Measure	Implementation	Technical Detail / Rationale
Secure Remote MGMT	Use of Encrypted SSH Tunnels from the Host Mac to the Edge-VM.	Provides a secure path for GUI access without exposing the OPNsense WAN interface.
Resource Isolation	Segmented network adapter configuration via VMware Fusion vmnets.	Provides Layer 2 isolation comparable to physical VLANs, preventing packet sniffing between zones.
Snapshot Baseline	Master-VM snapshots used for consistent, hardened deployments.	Allows for immediate rollback to a "Known Good State" if a VM is compromised during testing.

Logging & Monitoring Plan

This **Logging & Monitoring Plan** establishes the visibility required to detect, investigate, and respond to security incidents within the segmented lab environment. The strategy centers on the **SEC-VM** (192.168.0.227) acting as the centralized **Wazuh Manager**.

1. Log Sources & Inventory

Logs are categorized based on their origin and the type of telemetry they provide.

Source Category	Specific Component	Log Types	Rationale
Network Gateway	OPNsense	Firewall (Filter), DHCP, DNS (Unbound), VPN/SSH	Monitoring perimeter ingress/egress and inter-VLAN traffic.
Identity Services	D-VM	Samba AD logs, Auth logs (/var/log/auth.log), Syslog	Detecting credential abuse, failed logins, and account changes.
Perimeter Proxy	EDGE-VM	Proxy access logs, SSH logs, System logs	Identifying early-stage probing and perimeter exploitation attempts.
Management	MGMT-VM	User activity, Sudo logs, System health	Monitoring administrative actions for potential account compromise.
Security Stack	SEC-VM	Wazuh internal logs, File Integrity Monitoring (FIM)	Ensuring the integrity of the monitoring infrastructure itself.
External/Tools	NET-VM	Tool execution logs, System logs	Auditing activity in the "Internet" simulation segment.
Virtualization	VMware Fusion / Host Mac	Local Log Export	Forensics (Snapshot/NIC Manipulation)
Endpoint Security	Linux Auditd (on all	Wazuh Agent	Detailed command

	VMs)		history (Who did what?)
System Health	Disk/CPU/RAM Metrics	Wazuh / NetData	Ensuring SIEM availability and log integrity

2. Collection Method

The architecture utilizes a push-based model to aggregate logs onto the **SEC-VM** (Wazuh SIEM).

- **Wazuh Agent (Encrypted TCP 1514/1515):** Installed on all Linux endpoints (**MGMT, ID, EDGE, NET**). These agents provide real-time log collection, File Integrity Monitoring (FIM), and Rootkit detection.
- **Syslog over TLS (TCP/6514):** Configured on the **OPNsense** gateway to forward firewall and system logs securely to the **SEC-VM**, as OPNsense typically does not run a dedicated Wazuh agent.
- **NetFlow/IPFIX: OPNsense** is configured to export flow data to the **SEC-VM** for network traffic analysis (identifying "Top Talkers" and unusual traffic patterns).

3. Retention Policy

To balance resource constraints on the MacBook Air M3 with forensics requirements, a tiered retention policy is implemented:

Data Tier	Storage Type	Retention Period	Rationale
Active Alerts	Hot (Searchable)	30 Days	High-performance access for active incident response.
Security Logs	Warm (Compressed)	90 Days	Standard window for threat hunting and root-cause analysis.
Compliance/Archive	Cold (Archived)	180 Days	Long-term storage for identifying persistent threats or compliance audits.

Dashboard Name	Primary Platform	Key Metrics & Content	Primary Objective
A. Security Operations	Wazuh SIEM	Authentication Failures (SSH/Samba), Integrity Alerts (FIM for /etc, /bin), Vulnerability Overview	Real-time detection of brute-force attacks, unauthorized file changes, and misconfigurations.
B. Network Traffic	OPNsense	Top Blocked Destinations, Inter-VLAN Flow (VLAN 20/30), Interface Throughput	Monitoring perimeter defense integrity, lateral movement attempts, and potential data exfiltration.
C. Asset & Compliance	Wazuh SIEM	Active VM Inventory (MGMT, ID, SEC, etc.), OS versions, and prioritized CVE list	Proactive management of the Attack Surface and tracking of system-wide patch status.
D. System Integrity & Health	Wazuh / Host Metrics	Wazuh Manager service status, SEC-VM resource usage (CPU/RAM), and remaining Disk capacity	Ensuring 100% monitoring uptime and preventing data loss due to full storage partitions.

SOC Workflow

This SOC Workflow Definition establishes the operational structure, responsibilities, and timeframes required to ensure effective security monitoring of the network.

1. SOC Roles & Responsibilities

For a mid-sized enterprise environment, a lean but clearly defined hierarchy is essential to handle alert triage and incident response.

Role	Level	Core Responsibilities
SOC Analyst	Tier 1	Continuous monitoring of Wazuh and OPNsense dashboards. Performs initial alert triage, filters false positives, and documents security events.
Incident Responder	Tier 2	Performs in-depth analysis of validated threats. Executes containment and eradication measures and supports forensic investigations.
Security	Tier 3	Maintenance of the security stack (Wazuh/OPNsense).

Engineer		Performs periodic vulnerability scans and penetration tests to verify hardening status.
CISO	Management	Strategic oversight, risk management, and communication with executive leadership. Acts as the final escalation point for critical breaches.

2. Escalation Path

The escalation process follows a logical chain to ensure resources are utilized efficiently:

1. **Detection & Triage (Tier 1):** An alert is received in the Wazuh dashboard, and the Analyst assesses its relevance.
2. **Functional Escalation (Tier 1 → Tier 2):** If an alert is classified as a "True Positive" requiring active countermeasures, it is handed over to the Incident Responder.
3. **Critical Escalation (Tier 2 → CISO):** High-impact incidents (e.g., Ransomware or a compromise of the AD Domain Controller on the ID-VM) are escalated to the CISO for strategic decision-making

3. Service Level Agreements (SLAs)

SLAs define response expectations based on the criticality of the alert.

Priority	Example	Max. Response Time (TTA)	Max. Remediation Time (TTR)
P1 - Critical	Ransomware, Root access on OPNsense	15 Minutes	4 Hour
P2 - High	Successful brute-force in the ID zone	1 Hour	8 Hour
P3 - Medium	Vulnerability scan hits (CVEs)	4 Hour	3 Business Days
P4 - Low	Single blocked ping on WAN	24 Hour	N/A

4. Operational Additions

- **Vulnerability Management:** The **Security Engineer** performs monthly scans using tools like OpenVAS on the SEC-VM to ensure the hardening status defined in Segment 1 is maintained.

- **Proactive Monitoring:** Instead of a dedicated threat hunting team, **Tier 3** performs weekly reviews of OPNsense flow logs to identify anomalies that may not have triggered automated alerts.

Incident Response Process

This Incident Response (IR) Playbook provides a high-level framework for handling security events, using a Brute-Force Attack on the Identity VM (Samba AD) as a primary example to demonstrate the workflow between SOC tiers.

1. Incident Response Lifecycle: Brute-Force & Lateral Movement

This playbook follows the standard IR phases to ensure a structured response to a compromise of the Identity services.

Phase	Responsible Role	Action Steps
Detection & Analysis	SOC Analyst (Tier 1)	Wazuh SIEM triggers an alert for "Multiple authentication failures" followed by a "Successful login" from an unusual IP. Tier 1 verifies the alert against OPNsense flow logs to confirm the source.
Containment	Incident Responder (Tier 2)	Short-term: Disable the compromised user account in Samba AD. Long-term: Use OPNsense to isolate the ID-VM by disabling its "Allow Identity to Internet" rule, preventing command-and-control (C2) communication.
Eradication	Security Engineer (Tier 3)	Identify and remove malicious scripts or persistence mechanisms on the ID-VM. Review the Hardening Plan to identify why the attack was successful (e.g., weak password policy) and remediate the root cause.
Recovery	Incident Responder (Tier 2)	Revert the ID-VM to a "Known Good" snapshot if deep persistence is suspected. Restore account access with mandatory password resets and verify connectivity via the Management Tunnel.
Post-Incident Activity	CISO / Tier 3	Conduct a "Lessons Learned" session. Update firewall rules or Wazuh correlation logic to detect similar patterns faster in the future.

2. Technical IR Capabilities

The segmented architecture of the lab provides specific technical levers for each IR phase:

- **Detection:** Visibility is provided by the Wazuh Dashboard (Security Operations) and OPNsense (Network Traffic).
- **Containment:** The use of VLAN Isolation allows for the immediate "cutting off" of entire network segments without impacting other zones (e.g., isolating the ID-VM while keeping the MGMT-VM online).
- **Eradication:** Vulnerability Scanning (OpenVAS) on the SEC-VM is used post-incident to ensure no other entry points were left open.
- **Recovery:** VMware Snapshots provide a rapid recovery path, fulfilling the "Recover" function of the NIST CSF.

3. Strategic Escalation

- If the incident involves a potential **Data Breach** of the Samba AD database, the **Incident Responder** must escalate to the **CISO**.
- The CISO evaluates the risk and decides on external communication or legal requirements, ensuring the response aligns with the **Framework Selection** (NIST CSF Govern/Respond).

Implementation Roadmap

This roadmap outlines the phased rollout of security controls, monitoring capabilities, and SOC operations. It ensures that foundational protections are in place before monitoring begins and that the SOC team is fully onboarded before the system goes live.

Phase	Focus Area	Key Tasks	Duration	Dependencies
Phase 1	Protections & Hardening	Deployment of final Firewall ACLs; Implementation of SSH Key-based Auth; Execution of OS Hardening scripts on all VMs.	Week 1	Segment 1 Network Foundation
Phase 2	Monitoring Build-out	Installation of Wazuh Manager on SEC-VM; Deployment of Wazuh Agents to MGMT, ID, and EDGE VMs; Configuration of Syslog for OPNsense.	Week 2	Phase 1 Completion

Phase 3	SOC Onboarding	Configuration of Security Dashboards; Training SOC Analysts on the Incident Response Playbook; Establishing communication channels.	Week 3	Phase 2 Visibility
Phase 4	Validation & Go-Live	Full-scale Vulnerability Scan; Execution of "Purple Team" drills (simulated Brute-Force); Transition to 24/7 continuous monitoring.	Week 4	All previous phases

Rationale for Sequencing

The roadmap follows a dependency-aware logic to ensure operational success:

1. **Protections First:** Hardening measures and firewall rules are prioritized to reduce the immediate attack surface before exposing services to broader traffic.
2. **Monitoring Second:** Once the environment is "sealed," the monitoring stack is deployed to establish a baseline of "normal" behavior.
3. **Onboarding Third:** Personnel are onboarded only when the tools (Dashboards/Alerts) are functional, ensuring that training is conducted on a live, data-rich environment.
4. **Validation Final:** The final phase uses the established IR Playbook to test the entire chain of detection, escalation, and remediation before the project is considered complete.